

Tiago Brachini

Global IT Audit Specialist | IT Audit | IT Risk | SOX ITGC & ITAC | Cloud (AWS, GCP) | AI-enabled audit

Bragança Paulista, SP, Brazil (UTC-3) | tvobrachini@gmail.com | linkedin.com/in/tvobrachini | tvobrachini.github.io | github.com/tvobrachini

SUMMARY

IT auditor with 10+ years across Big Four (PwC) and three publicly listed fintechs (Nubank, MercadoLibre, StoneCo). Specialized in IT general and application controls (ITGC/ITAC), SOX/ICFR, SDLC governance and cloud security (AWS, GCP). Builds audit data analytics and AI tooling, from SQL, Python and Scala to open-source multi-agent audit automation with human review at each stage. Maps controls and plans audit scope with the Secure Controls Framework (SCF) metaframework; uses AI for data visualization and web publishing.

EXPERIENCE

Nubank

Nu Holdings (NYSE: NU) | 140M+ customers (Brazil, Mexico, Colombia) | US launch Sep 2026 | São Paulo

Global IT Audit Specialist | Sep 2025 – Present

IT Internal Auditor | Mar 2023 – Sep 2025

- Plan and lead risk-based IT and cybersecurity audits of SDLC governance, security governance and cloud environments (AWS, GCP), from risk assessment and scoping to reporting; evaluate ITGCs (identity and access management, change management, program development, IT operations) and risk and control matrices (RCMs).
- Rate IT risks by likelihood and impact, review risk assessments and risk-acceptance requests, challenge the proposed treatment, and track exceptions and corrective action plans to closure; report audit results to technical and non-technical stakeholders, mainly engineering leads and general managers.
- Automate audit testing and data analytics with Databricks and Scala; drive the use of AI tools in audit documentation and control testing; report with Google and AWS tools and Power BI.
- Run audits and issue tracking in an in-house audit management tool built on Jira; audit third-party (vendor) risk (TPRM) and review SOC 2 Type II and ISAE reports; test against control frameworks (ISO 27001, PCI DSS, NIST CSF), mapping controls and scoping with the SCF.
- Audit an SEC-registered group (Form 20-F, SOX/ICFR) in a highly regulated sector (Brazilian entities regulated by the Banco Central do Brasil), with multinational scope: auditees in Brazil, Mexico, Colombia, Germany and the US.

MercadoLibre

NASDAQ: MELI | E-commerce and fintech, 18 Latin American countries | Osasco

IT Internal Auditor | Nov 2021 – Mar 2023

- Planned and executed risk-based technical and operational SOX audits across Latin America, including ITGC testing and cloud security reviews; ran walkthroughs and interviews with process and control owners and coordinated with external auditors.
- Led regional IT audit projects with multinational teams.
- Built automated audit data analytics in Python (Pandas) and BigQuery SQL for high-volume environments.
- Audited an SEC-registered group (Form 10-K, SOX) whose payments arm, Mercado Pago, is a Banco Central do Brasil regulated payment institution; covered third-party risk (TPRM), SOC 2 and ISAE report review, and SAP and Oracle audit programs.

StoneCo

NASDAQ: STNE | 1.7M+ active clients (2021) | São Paulo

IT Internal Auditor | Feb 2021 – Nov 2021

- Ran risk-based SOX IT (ITGC and ITAC) and operational audits of payment, antifraud and core financial applications, including environments in PCI DSS scope.
- Automated control testing and audit data analytics with ACL, Python and BigQuery; managed audits in Perinity GRC.
- Audited an SEC-registered group (Form 20-F, SOX) whose payment institution (acquirer and e-money issuer) is regulated by the Banco Central do Brasil; covered third-party risk (TPRM), SOC 2 and ISAE report review, and SAP and Oracle audit programs.

PwC Brazil

Risk Assurance | São Paulo

Senior Associate | Jul 2018 – Feb 2021

Experienced Associate | Jul 2017 – Jul 2018

Associate | Jul 2016 – Jul 2017

Trainee | Jul 2015 – Jul 2016

- Planned and executed IT and business process audits (ITGC, SOX/ICFR) for major financial institutions and other clients, applying COSO and COBIT.
- Prepared and reviewed SOC 1 and SOC 2 attestation engagements for clients, alongside ITGC and SOX/ICFR audits.
- Built process flowcharts and risk and control matrices (RCMs); tested control design and operating effectiveness (TOD/TOE), including system-generated reports (IPE) and segregation of duties.
- Coordinated audit teams, prepared and reviewed working papers (including staff workpapers); evaluated deficiencies, documented findings and recommendations, followed up on remediation with management and drafted completion reports.

Earlier (2011–2015): software development in PHP, ASP/VB6, ASP.NET/C# and Django (Tmax Technology 2014–2015, OSG Sulamericana 2012–2013, 3Wise Tecnologia 2011–2012); IFSP research internship on the semantic web (2012).

OPEN-SOURCE PROJECTS (PERSONAL)

- **GRC Audit Swarm** (Python, CrewAI): multi-agent audit platform across Planning, Fieldwork and Reporting, with QA agents that reject and retry, human approval between phases, read-only AWS evidence collection (boto3), a SHA-256-hashed evidence vault, AWS account-ID redaction, and OSCAL export. github.com/tvobrachini/grc-audit-swarm
- **SCF Auto-Crosswalker** (Python, LLM): suggests Secure Controls Framework control IDs for IT policies, AWS Security Hub findings and audit scopes, for human review, and checks a control list against frameworks such as SOC 2 per requirement (gap analysis, no language model). CSV and OSCAL export; CI with ruff and bandit. github.com/tvobrachini/scf-auto-crosswalker

EDUCATION

- Tecnólogo (Brazilian higher-education undergraduate technology degree) in IT Management, FATEC Bragança Paulista, 2012
- Science Without Borders exchange program, Computer Science, Trinity College Dublin, 2013–2014

TRAINING

AWS Cloud Audit Academy – Cloud Agnostic (2021)

PUBLICATION

Impact of systemic management on project development: a study in a software house ([ResearchGate](#))

SKILLS

- **Governance & risk:** SOX/J-SOX, ICFR, ITGC (access management, change management, program development/SDLC, IT operations), ITAC, COSO, COBIT, ITIL, PCAOB standards, IIA standards, third-party risk management (TPRM) audits, SOC 1 and SOC 2 attestation (preparer and reviewer), SOC 2 and ISAE assurance report review, NIST CSF, ISO 27001, PCI DSS, SCF (metaframework for control mapping and audit planning), BCP/DR
- **Regulation:** LGPD/GDPR (privacy), CMN Res. 4893 (cyber policy and cloud), Res. BCB 85 (payment institutions)
- **Audit tools & ERP:** Perinity GRC (StoneCo), in-house Jira-based audit management (Nubank), ServiceNow GRC, Jira; SAP and Oracle (audit work programs applied)
- **Security & cloud:** AWS, GCP, IAM, SDLC/DevSecOps, vulnerability management
- **Data & automation:** SQL, Python, Scala, Databricks, BigQuery, ACL, Alteryx, Power BI, Google and AWS reporting, CrewAI, LangGraph, Docker, GitHub Actions
- **Languages:** Portuguese (native), English (fluent), Spanish (basic)